

The Value of Strong Identity and Access Management for ICS/OT Security

Mohammad Reza Nosouhi^{*†}, Zubair Baig^{*†}, Robin Doss^{*†}, Praveen Gauravaram[‡], Debi Prasad Pati[§], Divyans Mahansaria[§], Keshav Sood^{*†}, and Lei Pan^{*†}

^{*} Deakin Cyber Research and Innovation Centre, Deakin University, Geelong, Australia

[†] Cyber Security Cooperative Research Centre (CSCRC), Joondalup, WA 6027, Australia

[‡] Tata Consultancy Services (TCS) Ltd., Brisbane, Australia

[§] Tata Consultancy Services (TCS) Ltd., Kolkata, India

Abstract—As the integration of digital technologies with Industrial Control Systems (ICS) and Operational Technology (OT) continues to deepen, these systems increasingly become targets for sophisticated cyber attacks. These attacks not only threaten the operational integrity but also pose significant risks to national security and public safety. In this paper, we provide insights into the value of ICS/OT security solutions that are based on Identity and Access Management (IAM). Beginning with presenting an abstraction model for typical ICS/OT attacks, the paper systematically outlines the main stages of an attack and the corresponding vectors employed by adversaries. Drawing from the MITRE ATT&CK framework tailored for ICS, the paper quantifies the extent to which IAM-based mitigation approaches can strengthen defense-in-depth mechanisms against cyber threats targeting ICS/OT environments. Our findings show that there are modern attack vectors that can only be mitigated through robust IAM solutions. Moreover, we found that while advanced techniques such as firewall and gateway-based intelligent threat detection play a significant role in safeguarding ICS/OT, they are insufficient on their own to address several attack vectors in ICS/OT environments.

Index Terms—Attack Model, Identity and Access Management, Industrial Control Systems, Operational Technology, Security

I. INTRODUCTION

Operational Technology (OT) and Industrial Control Systems (ICS) are the backbone of critical infrastructures. These systems play a fundamental role in ensuring the efficient operation of essential services and processes, making them prime targets for malicious actors seeking to disrupt operations or cause widespread damage. Traditionally, ICS and OT have operated in isolated environments, detached from other information networks, and shielded from external cyber threats by virtue of this separation. However, the past decade has seen a paradigm shift with the increasing convergence of IT and OT environments, stimulated by the drive towards greater efficiency and data accessibility. This integration, while beneficial, has significantly expanded the attack surface, exposing critical infrastructures to sophisticated cyber threats. To effectively defend against such threats, it is imperative to adopt a proactive and multifaceted approach to ICS/OT security.

Despite the growing recognition of cybersecurity threats in ICS/OT environments, the existing literature exhibits notable gaps in providing a comprehensive understanding of

the ICS/OT attack landscape leading to potential confusion among readers. To address these limitations, this paper adopts a systematic approach to analyzing the threat landscape in ICS/OT environments. We begin by presenting a generalized abstraction model for a typical attack on ICS/OT environments, simplifying the main stages of an attack and the associated vectors employed by adversaries. Drawing upon the MITRE ATT&CK framework tailored for ICS [1], we explore the techniques utilized by attackers at each stage of the attack lifecycle. For each identified attack vector, we analyze the standard mitigation techniques based on MITRE ATT&CK framework. The main focus of our analysis is the evaluation of IAM's effectiveness in mitigating attack vectors targeting ICS/OT systems. Our findings reveal that IAM-based approaches can effectively mitigate a significant portion of attack vectors, particularly 86% of those used to perform lateral movement. The latest CISA post [2] which recommends the implementation of MFA across all access to ICS/OT, also echoes our findings. The following are our contributions:

- We evaluate the value of IAM-based solutions for ICS/OT by presenting an abstract attack model and map this model with attack vectors based on real world incidents on critical infrastructures.
- We provide insights into the imperative deployment of IAM-based solutions for ICS/OT security as well as some limitations of advanced ICS/OT security solutions (e.g., firewall/gateway-based intelligent threat detection approaches), underscoring the necessity for supplementation with IAM-based techniques to attain comprehensive Zero Trust security measures.

The paper is organized as follows. In Section II, we present the generalized attack model that outlines the stages of a typical attack. Section III, present our IAM impact analysis along with a brief comparison between IAM-based solutions and state-of-the-art techniques. In Section IV, we present the challenges of IAM integration in OT environments. Finally, Section V summarizes the paper.

II. THE ABSTRACTION ATTACK MODEL

This section presents an abstraction model that simplifies the main stages of cyber attacks targeting ICS/OT systems. We utilize this model to cover the structure of most of the known attacks on ICS/OT by breaking down an attack into five general

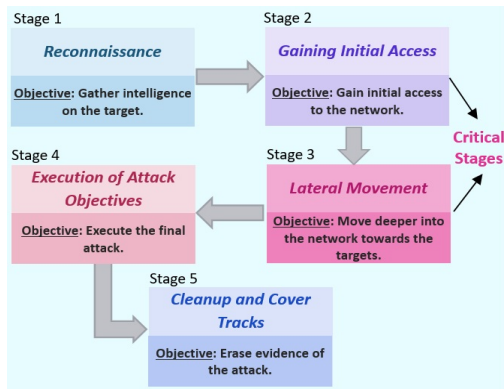


Fig. 1: The considered abstraction attack model.

stages. An attack may not necessarily include all these stages, but this framework captures the general behavior observed across various attack scenarios against ICS/OT environments.

It should be noted that each of these stages can encompass a variety of sub-stages that represent more detailed actions or tactics that attackers employ as they progress through each main stage of the attack. These sub-stages are context-dependent and vary widely based on the specific security architecture, operating systems, and operational procedures of the target system.

In the following we presents the stages considered in our abstraction model (see Fig. 1).

A. Reconnaissance

The first stage of the model is Reconnaissance, where attackers gather information about the target system. This stage involves identifying vulnerable points, understanding network topologies, and collecting data on the operational processes and the technologies in use.

Attack Vectors: Attackers may employ techniques such as network scanning, social engineering, public sources, or Open-Source Intelligence (OSINT) datasets to gain a comprehensive understanding of their target.

B. Gaining Initial Access

Once sufficient information has been collected, attackers proceed to the Gaining Initial Access stage which is critical as it determines the attacker's ability to penetrate the system.

Attack Vectors: According to MITRE ATT&CK ICS Matrix [1], there are 12 known attack vectors utilized by adversaries for initial access to ICS/OT systems as follows.

Drive-by Compromise: This is also known as watering hole attack in which attackers first compromise a specific website which is often visited by the targeted user. Then they exploit vulnerabilities in the user's web browser or browser plugins to install malware once the user visits the compromised website. Example: ALLANITE [3].

Exploitation of Public-Facing Application: This vector involves attacking vulnerabilities in software that is accessible

from the internet, such as web servers or web-based interfaces on an ICS network. Example: Sandworm Team [4].

Exploitation of Remote Services: Attackers exploit vulnerabilities, misconfigurations, or programming errors in services accessible over the network to gain unauthorized access. Example: WannaCry [5].

External Remote Services: This involves exploiting weak security practices of remote services provided by third-party organizations to gain access to an organization's network from external locations (e.g., VPNs, or other remote access software). Example: The Ukraine Electric Power Attack [6].

Internet Accessible Device: Devices that are directly accessible from the internet (rather than through External Remote Services.), without adequate security measures, can be directly targeted and exploited to gain initial access to the network. It should be noted that in this vector, attackers use no exploits to access onto these devices, otherwise this vector would be considered as a Exploitation of Public-Facing Application vector. Example: Unitronics Defacement Campaign [7].

Remote Services: This vector focuses on potential ability of attackers to utilize remote services (using valid accounts rather than exploiting a vulnerability) deployed within an organization to move between network segments. These services are deployed to support system access and data transmission for legitimate operators remotely within the network. Example: Triton Safety Instrumented System Attack [8].

Replication Through Removable Media: Malware is introduced to a system through removable media, like USB drives, that has been infected by connecting it to other compromised devices or systems. Example: Conficker [9].

Rogue Master: In this vector, attackers set up an unauthorized device to act as a master on a control system network (or impersonating a master) to utilize control server functions and send legitimate control messages to field devices, potentially leading to malicious actions or configuration changes. Example: Maroochy Water Breach [10].

Spear-Phishing Attachment: Attackers target specific individuals (e.g., those with specific access rights in the network) by sending email to them where the recipient is tricked into opening an attachment that contains malware, leading to the system's compromise. Example: Chinese Gas Pipeline Intrusion Campaign [11].

Supply Chain Compromise: Adversaries infiltrate a supplier or service provider and compromise their components or software before they are received by the primary target, gaining access when these compromised resources are integrated. Example: SolarWinds Compromise [12].

Transient Cyber Asset: This involves devices that are not permanently part of the network (like laptops, diagnostic equipment, or any mobile device) but may be connected to the network, i.e., may be carried (by authorized personnel) from any external networks to the ICS network. These can introduce malware if they have been compromised when used outside the network. Example: Maroochy Water Breach [10].

Wireless Compromise: Attackers exploit wireless networks to gain unauthorized access. This can involve compromising Wi-

Fi networks, exploiting vulnerabilities in wireless protocols, or intercepting unencrypted wireless communications. Example: Maroochy Water Breach [10].

C. Lateral Movement

Once initial access is gained, typically in an IT environment, attackers often seek to laterally move deeper into OT systems which often have higher value or sensitivity than the initial point of compromise.

Attack Vectors: According to MITRE ATT&CK ICS Matrix [1], adversaries may use 7 attack vectors for lateral movement as follows.

Default Credentials: Attackers exploit devices or systems within the network that still use default or weak credentials, which are often unchanged from their factory settings. By exploiting these credentials, attackers can move laterally across the network. Example: Unitronics Defacement Campaign [13].

Exploitation of Remote Services: See Section II-B.

Hardcoded Credentials: Some devices or applications may have hardcoded credentials embedded within their code or configuration files. Attackers can extract these credentials to gain unauthorized access and move laterally within the network. Example: INCONTROLLER [14].

Lateral Tool Transfer: Attackers transfer tools or utilities to compromised systems to aid in lateral movement. These tools may include specialized software for network scanning, password cracking, or remote administration. Example: The Ukraine Electric Power Attack [6].

Program Download: To facilitate lateral movement, attackers can trigger a program download to transfer a malicious program to a controller (e.g., a PLC) after ensuring the controller is in the proper mode to accept a program download. The program may include malware, remote access tools, or exploit payloads designed to help the attacker gain further access within the network. Example: PLC-Blaster [15].

Remote Services: See Section II-B.

Valid Accounts: Attackers abuse legitimate user accounts with sufficient permissions to move laterally within the network. This could involve using stolen credentials obtained through phishing or other means, or exploiting misconfigured access controls to escalate privileges and move laterally. Example: The Ukraine Electric Power Attack [6].

D. Execution of Attack Objectives

The fourth stage is where the attacker's primary goals are carried out. Depending on the attacker's intentions, this could involve disrupting operational processes, manipulating control systems, exfiltration, or injecting ransomware.

Attack Vectors: In this stage, adversaries may employ various attack vectors to achieve their objectives including the *Impact* category of attack vectors specified in the MITRE Att&ck ICS Matrix. This category includes *Damage to Property*, *Denial of Control*, *Denial of View*, etc.

E. Cleanup and Cover Tracks

The final stage involves Cleanup and Cover Tracks, where attackers attempt to erase their tracks to avoid detection and preserve their access for potential future exploitation. This may include deleting logs, uninstalling malware, and removing any other evidence of their activities. Maintaining stealth during this phase ensures that the attack can remain undetected, allowing for prolonged exploitation and potentially complicating forensic efforts.

III. THE VALUE OF IAM-BASED MITIGATION TECHNIQUES

In this section we explore the efficacy of IAM-based techniques in protecting ICS and OT systems.

A. Identification of Critical Stages

It is crucial to identify and prioritize the most critical stages of attacks on ICS/OT. Based on the considered abstraction model, two stages stand out as particularly critical: **Stage 2** (Gaining Initial Access) and **Stage 3** (Lateral Movement). Effectively preventing or mitigating these stages is crucial, as doing so significantly reduces the likelihood of an attack progressing further. Stage 2 represents the point at which attackers first breach the perimeter of an ICS/OT environment, gaining a foothold within the network. Similarly, Stage 3 marks the phase where attackers attempt to expand their control and navigate deeper into the network, often compromising additional systems and escalating privileges along the way.

B. The Role of IAM

IAM encompasses a range of techniques, including authentication, access management, privileged account management, authorization, that are instrumental in controlling and securing user access to critical resources. Our analysis on the attack vectors for critical Stages 2 and 3 reveals compelling insights into the effectiveness of IAM-based techniques in mitigating cyber threats within ICS and OT environments. By examining the mitigation techniques recommended in the MITRE ATT&CK database, we found that IAM-based solutions offer significant potential for enhancing the security posture of ICS/OT systems (Table I lists those attack vectors of critical stages 2 and 3 that can be significantly mitigated using IAM-based techniques). Specifically, our analysis indicates that 42% of attack vectors targeting Stage 2 and 86% of attack vectors targeting Stage 3 can be effectively mitigated through the implementation of IAM-based techniques (see Fig. 2). These findings underscore the pivotal role of IAM in fortifying ICS/OT systems against a wide range of cyber threats, highlighting its importance as a cornerstone of effective cybersecurity defense strategies in critical infrastructure environments.

C. IAM Integration: Fortifying Modern Security Solutions

While IAM-based solutions offer significant advantages in mitigating cyber threats within OT/ICS environments, it is essential to compare them with state-of-the-art solutions to understand their relative effectiveness and limitations.

TABLE I: List of the attack vectors that can be significantly mitigated using IAM-based techniques.

Attack Vector	Attack Stage	IAM-based Mitigation Techniques
Exploitation of Public-Facing Application External Remote Services Rogue Master	Gaining Initial Access	Privileged Account Management MFA, Account Management, Account & Password Policies Service Account Authentication/Authorization
Exploitation of Remote Services Remote Services Default Credentials Hardcoded Credentials Program Download Valid Accounts	Gaining Initial Access & Lateral Movement	Privileged Account Management Authentication, Access & Account Management, Authorization, Password Policies Access Management, Password Policies Access Management
	Lateral Movement	Authentication, Access Management, Authorization MFA, Access Management, Account & Password Policies, Privileged Account Management

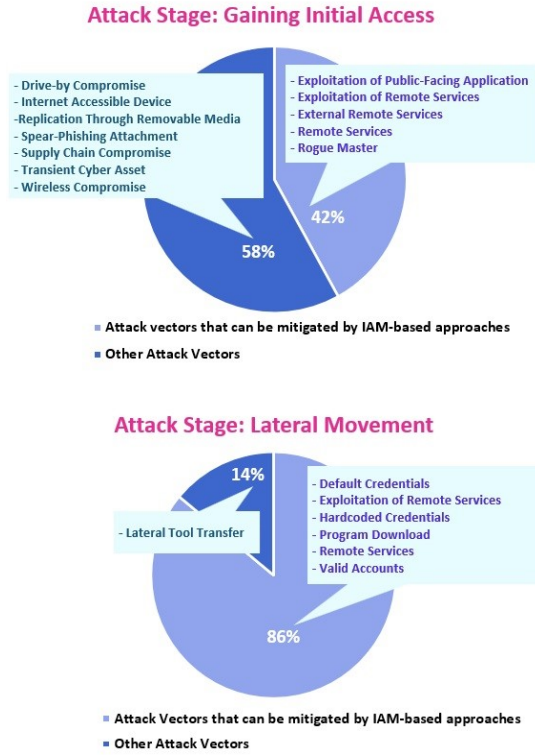


Fig. 2: The value of IAM for threat mitigation in ICS/OT.

Unique Mitigation Capabilities of IAM: According to the MITRE ATT&CK framework, certain attack vectors targeting critical Stages 2 and 3 can be mitigated only through IAM-based techniques. For example, vulnerabilities such as *Default Credentials* and *Hardcoded Credentials* are best addressed through robust IAM policies and controls, highlighting the unique advantages of IAM in securing OT/ICS systems.

Limitations of Modern Threat Detection Methods: Despite advancements in threat detection technologies, there are attack vectors identified by the MITRE ATT&CK framework for critical Stages 2 and 3 that remain challenging to mitigate using modern intelligent threat detection methods. For instance, vectors like *External Remote Services* or *Default/Hardcoded Credentials* pose significant challenges for state-of-the-art solutions, underscoring the need for complementary security measures beyond threat detection approaches.

Moreover, modern solutions that rely on AI techniques for

traffic analysis, may exhibit critical disadvantages in certain scenarios. These include limited capabilities, particularly when dealing with encrypted traffic, as they may fail to protect against adversaries that use non-standard encryption methods.

IV. IAM INTEGRATION CHALLENGES

IAM processes for OT/ICS differ significantly from IT, especially in access request, approval, and granting. OT system users can be in remote locations with limited connectivity, hindering user authentication methods like SMS. Implementing IAM in OT/ICS environments presents several unique challenges. Firstly, OT/ICS environments often include legacy systems that were not designed with modern security standards in mind. These systems may lack the necessary interfaces or capabilities to integrate with contemporary IAM solutions. Secondly, OT/ICS environments can be highly complex, with a wide variety of devices, systems, and protocols. This heterogeneity makes it difficult to implement a unified IAM solution. Moreover, in industrial environments, system availability is critical. IAM implementations must ensure that security measures do not introduce downtime or affect the performance of critical systems. In addition, OT networks are often segmented from IT networks for security reasons. Implementing IAM across segmented networks requires careful planning to ensure secure and seamless integration. It should be noted that there is often a cultural divide between IT and OT personnel, e.g., OT staff may prioritize operational reliability over security, leading to resistance against IAM implementation.

V. CONCLUSION

This paper highlights the critical importance of IAM in mitigating ICS/OT cyber threats through analysis of attack vectors as aligned with the MITRE ATT&CK framework. The paper findings indicate that IAM-based approaches can effectively mitigate a significant portion of attack vectors at key stages of the attack lifecycle, particularly 86% of those used to perform lateral movement. Furthermore, to adhere to Zero Trust principles, the paper suggest that advanced ICS/OT security solutions, while crucial, are insufficient alone and need to be complemented by IAM techniques.

ACKNOWLEDGEMENT

This work has been supported by the Cyber Security Research Centre Limited (SAARACI Project, C13-00223), whose activities are partially funded by the Australian Government's Cooperative Research Centres Programme.

REFERENCES

- [1] Mitre att&ck-ics matrix. Accessed: 16th May 2024. [Online]. Available: <https://attack.mitre.org/matrices/ics/>
- [2] Defending ot operations against ongoing pro-russia hacktivist. [Online]. Available: <https://www.cisa.gov/sites/default/files/2024-05/defending-ot-operations-against-ongoing-pro-russia-hacktivist-activity-508c.pdf>
- [3] Allanite' group targets ics networks at electric utilities in us, uk. [Online]. Available: <https://www.securityweek.com/allanite-group-targets-ics-networks-electric-utilities-us-uk/>
- [4] M. McFail, J. Hanna, and D. Rebori-Carretero, "Detection/engineering in industrial control systems. ukraine 2016 attack: Sandworm team and industroyer case study," *MITRE CORP MCLEAN VA*, 2022.
- [5] D.-Y. Kao and S.-C. Hsiao, "The dynamic analysis of wannacry ransomware," in *2018 20th International conference on advanced communication technology (ICACT)*. IEEE, 2018, pp. 159–166.
- [6] D. E. Whitehead and et. al, "Ukraine cyber-induced power outage: Analysis and practical mitigation strategies," in *70th Annual conference for protective relay engineers*. IEEE, 2017, pp. 1–8.
- [7] Breaches by iran-affiliated hackers... [Online]. Available: <https://apnews.com/article/hackers-iran-israel-water-utilities-critical-infrastructure-cisa-554b2aa969c8220016ab2ef94bd7635b>
- [8] The inside story of the world's most dangerous malware. Accessed: 16th May 2024. [Online]. Available: <https://www.eenews.net/articles/the-inside-story-of-the-worlds-most-dangerous-malware/>
- [9] Malware shuts down german nuclear power plant. Accessed: 16th May 2024. [Online]. Available: <https://news.softpedia.com/news/on-chernobyl-s-30th-anniversary-malware-shuts-down-german-nuclear-power-plant-503429.shtml>
- [10] M. Abrams and J. Weiss, "Malicious control system cyber security attack case study-maroochy water services, australia," *McLean, VA: The MITRE Corporation*, 2008.
- [11] Chinese gas pipeline intrusion campaign. [Online]. Available: [https://www.cisa.gov/sites/default/files/publications/AA21-201A_Chinese_Gas_Pipeline_Intrusion_Campaign_2011_to_2013%20\(1\).pdf](https://www.cisa.gov/sites/default/files/publications/AA21-201A_Chinese_Gas_Pipeline_Intrusion_Campaign_2011_to_2013%20(1).pdf)
- [12] R. Alkhadra and et. al, "Solar winds hack: In-depth analysis and countermeasures," in *12th International Conference on Computing Communication and Networking Technologies*. IEEE, 2021, pp. 1–7.
- [13] Irgc-affiliated cyber actors exploit plcs... [Online]. Available: <https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-335a>
- [14] Incontroller: New state-sponsored cyber attack tools target multiple industrial control systems. Accessed: 16th May 2024. [Online]. Available: <https://cloud.google.com/blog/topics/threat-intelligence/incontroller-state-sponsored-ics-tool/>
- [15] R. Spenneberg, M. Brüggemann, and H. Schwartke, "Plc-blasters: A worm living solely in the plc," *Black Hat Asia*, vol. 16, pp. 1–16, 2016.